

Security Incident Report:

yummyrecipesforme.com

Section 1: Identify the Network Protocol Involved in the Incident

Hypertext Transfer Protocol (HTTP) was the network protocol involved in this incident.

By running tcpdump while visiting yummyrecipesforme.com, we were able to identify the issue and record the DNS and HTTP traffic in a log file.

This evidence led us to conclude that the malicious file was delivered to users' computers over HTTP at the application layer.

Section 2: Document the Incident

Multiple customers contacted the website owner to report that, upon visiting the site, they were prompted to download and run a file claiming to be a browser update. After downloading it, their computers began running sluggishly. The website owner then attempted to log into the web server and discovered they had been locked out of their admin account.

To investigate, we set up a sandbox environment to interact with the website without putting the corporate network at risk. Using tcpdump, we captured the traffic generated while browsing the site, then accepted the download prompt (posing as a browser update) and ran the file. Doing so caused the browser to redirect to a separate site, greatrecipesforme.com — a near-identical copy of the original site, but offering the paid content for free.

Reviewing the tcpdump log, the browser first resolved and connected to yummyrecipesforme.com over HTTP as expected. Immediately after the malicious file was downloaded and executed, the traffic pattern changed: the browser requested a new DNS resolution, this time for greatrecipesforme.com, and all subsequent traffic was routed to that new address.

The sequence observed in the log was:

1. The browser requests DNS resolution for yummyrecipesforme.com.
2. The DNS server replies with the correct IP address.
3. The browser initiates an HTTP request for the webpage.
4. The browser downloads the malicious file.
5. The browser requests DNS resolution for greatrecipesforme.com.
6. The DNS server responds with the new IP address.
7. The browser initiates an HTTP request to the new address.

A review of the source code for both sites, along with the downloaded file itself, showed that an attacker had modified the original site to prompt visitors to download a file disguised as a browser update. Combined with the website owner being locked out of their admin account, this points to the attacker likely using a brute force attack to gain access and change the admin password — allowing them to plant the malicious download that later compromised end users' machines.

Section 3: Recommend Remediations for Brute Force Attacks

To reduce the risk of this happening again, the team plans to implement two-factor authentication (2FA) on the admin account. This adds a second identity check — a one-time password (OTP) sent by email or phone — on top of the normal login, making it much harder for an attacker to get in even if they obtain the password.

The team also intends to strengthen the admin panel by limiting the number of login attempts allowed. After a set number of failed tries, the account would be temporarily locked, which cuts off automated brute force attempts before they can succeed.

Finally, the team is considering adding CAPTCHA challenges to login forms across the site, to help distinguish real users from automated scripts and bots attempting unauthorized access.